



PhishGuard

An Automated Phishing Email Analysis and Risk Scoring System

Information System Security Project

Dana Salem . Jameel Al Shurafa . Laila Sadideen

Road Map



Abstract

As cyber threats evolve, phishing remains a critical risk to both individuals and organizations. Current machine learning detection models often act as "black boxes," hindering security analysts' ability to understand why specific threats are flagged. To address this gap, we introduce PhishGuard, an automated and highly transparent email analysis system. Our approach utilizes a Python-based modular architecture to systematically evaluate email headers, domains, URLs, and attachments using standard static analysis tools. We implemented a severity-driven risk-scoring engine, which incorporates heuristic combination penalties, to automatically categorize emails into Allow, Quarantine, or Block statuses. We evaluated the model on a hybrid dataset of 240 email samples encompassing clean baselines, single-vector, and multi-vector attacks. The system achieved an overall accuracy of 80.00%, a precision of 87.88%, and a restrictive recall rate of 96.67%, allowing only two false negatives. In conclusion, our explainable, low-overhead triage workflow provides a practical alternative to opaque machine learning algorithms. By integrating multi-stage static analysis into a clear scoring framework, the system empowers analysts to make informed, evidence-based decisions, striking a robust balance between strict threat detection and operational transparency.

What is PhishGuard?

Automated phishing email analysis with transparent risk scoring



Automated Email Analysis

Analyzes suspicious emails automatically



Explainable Risk Scoring

Transparent scoring instead of black-box AI



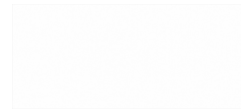
Multi-Layer Inspection

Checks headers, domains, URLs, and attachments



Final Security Decision

Allow / Quarantine / Block classification



The Phishing Threat Is Escalating

Phishing is one of the most pervasive and damaging forms of cyberattack — targeting individuals, enterprises, and governments through deceptive communication.

Email Phishing

Deceptive emails
impersonating trusted
senders

Spear Phishing

Highly targeted attacks
on specific individuals

Smishing

Phishing via SMS / text
messages

Vishing

Voice-based social engineering attacks

Pharming

Redirecting users to fraudulent
websites via DNS



Impact & Detection Challenges

Real-World Consequences

1. Financial Loss — Billions lost annually to phishing-driven fraud and wire transfer scams

2. Identity Theft — Stolen credentials fuel account takeovers and fraud

3. Malware Infection — Malicious attachments and links deploy ransomware and spyware

4. Business Damage — Reputational harm, regulatory penalties, and data breaches

Why Detection Is Hard

- **Mimicry:** Phishing emails closely replicate legitimate communication — logos, tone, and domain names
- **Evolving Tactics:** Attackers continuously adapt to bypass static rule-based filters
- **Human Factor:** Social engineering exploits trust and urgency, bypassing technical defenses
- **No Silver Bullet:** No single indicator is sufficient — detection requires multi-layer evidence

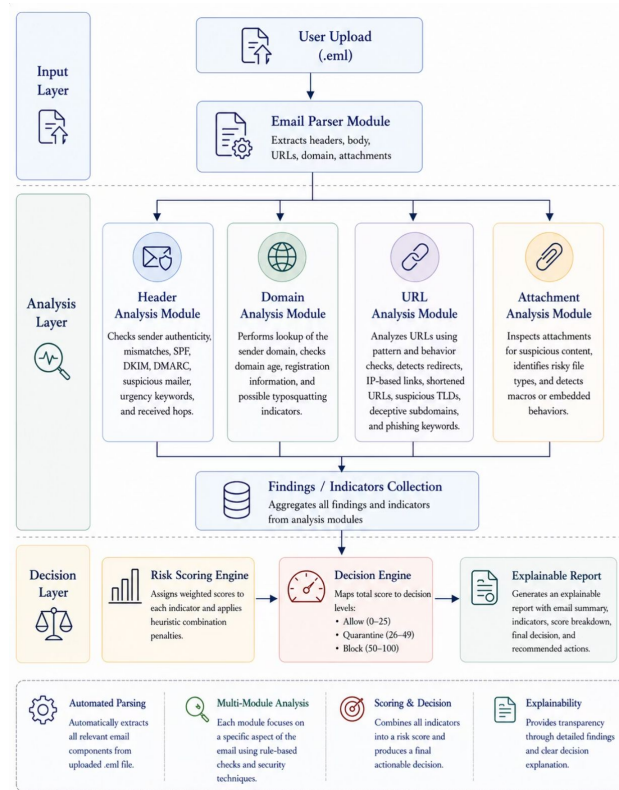
Literature Review

Phishing detection research has increasingly focused on data-driven techniques, with machine learning models using handcrafted features to identify suspicious URLs, sender behavior, and email content. More recent studies emphasize deep learning and AI methods that learn richer representations directly from raw text and message structure, improving adaptability to evolving attack patterns. Natural language processing has also become central to this field, enabling systems to analyze intent, linguistic cues, and contextual inconsistencies in phishing messages. Transformer-based models represent the current direction of modern research, offering strong performance in classifying complex and subtle phishing content across email, web, and social media environments.

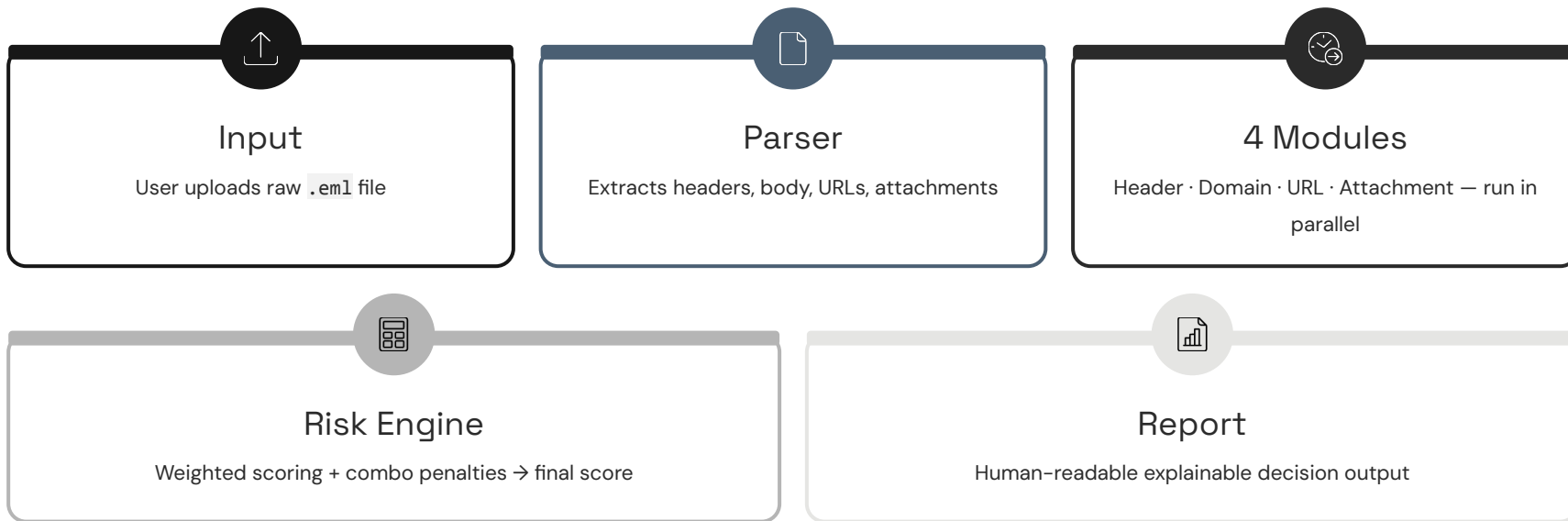
Related Work Comparison

Research Paper	Technique/Model Used	Advantages	Limitations
Omotosho [11]	Hybrid (ML + Rule-based)	High accuracy for known phishing types; combines expert rules with learning.	May struggle with zero-day attacks; rule-set maintenance can be challenging.
Zaimi et al. [15]	Deep Learning (CNN-LSTM)	Adapts to evolving tactics; less reliance on handcrafted features.	High computational cost; requires large datasets; interpretability issues.
Ahmad et al. [17]	Natural Language Processing (BERT-based embeddings)	Excellent at detecting sophisticated social engineering; high generalizability.	Very high computational demands; sensitive to dataset bias; model complexity.

PhishGuard — System Architecture



PhishGuard — System Architecture



Four-Layer Email Inspection



Header Analysis

- SPF / DKIM / DMARC validation
- Sender address mismatch detection
- Received-chain hop anomalies



Domain Analysis

- WHOIS & domain age checks
- DNS record validation
- Typosquatting detection



URL Analysis

- Full URL parsing & redirect tracing
- Subdomain deception patterns
- URL obfuscation detection



Attachment Analysis

- File type & MIME detection
- Macro & script extraction
- PDF inspection & archive unpacking

Risk Scoring & Decision Engine

Scoring Formula

Feature Union: $F = H \cup D \cup U \cup A$

All findings from Header, Domain, URL, and Attachment modules are merged.

Raw Score: $\sum w(f_i)$

Each finding f_i carries a weight based on severity and confidence.

Final Score: $\min(\text{Raw} + \text{Combo}, 100)$

Combo penalties apply when correlated indicators appear together — capped at 100.

Decision Thresholds

1

 **Score: 0 – 25 → ALLOW**

Low risk — email passes to inbox

2

 **Score: 26 – 49 →
QUARANTINE**

Suspicious — held for review

3

 **Score: 50 – 100 →
BLOCK**

High risk — email is blocked
immediately

Scoring in Practice — Three Scenarios

CASE 1

✓ Decision: ALLOW

- Trusted, established domain (age > 5 years)
- SPF / DKIM / DMARC all pass
- No suspicious URLs or redirects
- No macros or risky attachments

✓ **Final Score: 0 / 100** — Clean email, no indicators triggered

CASE 2

⚠ Decision: QUARANTINE

- SPF check fails — unauthorized sending server
- Display name ≠ envelope sender address
- Domain registered < 30 days ago
- No malicious attachment detected

⚠ **Final Score: 41 / 100** — Suspicious signals, held for review

CASE 3

✗ Decision: BLOCK

- Domain resolves NXDOMAIN — does not exist
- Deceptive subdomain mimicking legitimate brand
- Malicious PDF with embedded JavaScript
- Multiple combo penalties triggered

✗ **Final Score: 100 / 100** — Maximum threat, blocked immediately

EVALUATION METRICS

Confusion Matrix

	Predicted Class		
	ALLOW	QUARANTINE	BLOCK
Expected ALLOW	54	28	8
Expected QUARANTINE	0	22	8
Expected BLOCK	2	2	116

Key Performance Indicators

Overall Accuracy = 80%

Precision = 87.9%

Recall = 96.7%

F1-Score = 92.1%

The model highly prioritizes security; out of 120 malicious test cases, only **2 were falsely allowed (False Negatives)**, resulting in a strict 96.67% recall rate.

Comparative Benchmark

The performance comparison in the Table shows how our proposed model, PhishGuard, balances strong threat detection with operational transparency. While traditional and deep-learning approaches like Random Forest (96.0% accuracy) and CNN-LSTM models (98.19% accuracy) report higher raw metrics, they often function as "black boxes." In contrast, our fully automated, static-analysis triage workflow avoids this computational overhead, achieving a highly restrictive recall of 96.67%, an accuracy of 80.00%, and a strong F1-Score of 92.06% while maintaining complete explainability for security analysts.

Model	Accuracy	F1-Score / Notable Metrics
Random Forest (Omotosho)	96.0%	Heavy tabular data reliance
Traditional ML / SVM (Sundararaj)	N/A	>80% Precision, Low Recall (60%)
CNN-LSTM (Zaimi et al.)	98.19%	High resource requirements
Proposed Model (PhishGuard)	80.00%	92.06% F1-Score (96.67% Recall)



Key Results & System Performance

4

Analysis Layers

Header, Domain, URL, and Attachment — all inspected in parallel

High Detection Accuracy — Multi-layer evidence correlation drastically reduces missed phishing emails

100

Max Risk Score

Normalized, capped scoring scale for consistent decision boundaries

Low False Negatives — Combo penalty system catches evasion attempts that fool single-layer detectors

3

Decision Classes

Allow · Quarantine · Block — clear, actionable outcomes

Full Explainability — Every decision is accompanied by a human-readable breakdown of contributing signals

Conclusion

1

Multi-layer analysis
Combines Header, Domain, URL & Attachment signals

2

Weighted scoring
Severity-aware, with combo bonuses for correlated threats

3

Explainable output
Justified, human-readable security reports

4

Modular design
Easily extended with new detectors or data sources

Strength Summary

Simple Yet Powerful — PhishGuard demonstrates that rule-based multi-layer analysis, without AI, can achieve strong detection performance on real-world phishing emails.

Transparent Decisions — Unlike black-box ML models, every score is explainable — users and administrators understand exactly why an email was blocked or allowed.

Practical Deployment — The modular architecture allows easy integration with existing mail gateways and extension with new detection modules.



Thank You

PhishGuard — Automated Phishing Email Analysis & Risk Scoring